

ISO/IEC 27001:2022

Anexo A — Evaluación de los 93 Controles de Seguridad de la Información

Tipo de documento:	Informe de evaluación de controles (uso de prueba)
Organización evaluada:	Empresa Demo S.A. (organización ficticia)
Alcance:	Anexo A completo — 93 controles / 4 dominios
Fecha de generación:	17 de junio de 2026
Finalidad:	Probar capacidades de análisis de un agente de IA

1. Objetivo del documento

Este documento presenta una evaluación de ejemplo sobre los 93 controles de seguridad de la información agrupados en los cuatro dominios del Anexo A de la norma ISO/IEC 27001:2022 (Organizacionales, Personas, Físicos y Tecnológicos). Su propósito es servir como insumo de prueba para validar la capacidad de un agente de inteligencia artificial de leer, interpretar y analizar documentos con estructura típica de auditoría: tablas de controles, indicadores, mapas de calor de riesgo y recomendaciones.

Todos los datos de estado, madurez, nivel de riesgo, responsables y fechas que aparecen en este informe son **sintéticos** y fueron generados de forma aleatoria con fines ilustrativos. No corresponden a una organización real ni representan una evaluación oficial de cumplimiento.

1.1 Estructura del documento

1. Metodología de evaluación: escalas de madurez y criterios de riesgo utilizados.
2. Resumen ejecutivo: indicadores globales de cumplimiento y madurez.
3. Mapa de calor general: visualización del nivel de riesgo de los 93 controles.
4. Mapa de calor por dominio y madurez promedio por dominio.
5. Detalle de controles: catálogo completo de los 93 controles del Anexo A con su evaluación.
6. Conclusiones y recomendaciones generales.

2. Metodología de evaluación

Cada control fue calificado según su **estado de implementación**, un **nivel de madurez** (escala 0 a 5) y un **nivel de riesgo residual** asociado. Esta combinación permite construir los mapas de calor que se presentan en las secciones siguientes.

2.1 Escala de madurez

Nivel	Descripción
0	Inexistente — el control no se ha definido ni implementado.
1	Inicial — existe de forma ad-hoc, sin documentación ni consistencia.
2	Repetible — se aplica de manera parcial o inconsistente entre áreas.
3	Definido — el control está documentado e implementado de forma estándar.
4	Gestionado — se mide, se supervisa y se ajusta con indicadores.
5	Optimizado — mejora continua basada en métricas y revisión periódica.

2.2 Niveles de riesgo

Nivel de riesgo	Criterio de asignación (simplificado)
Crítico	Control no implementado o con madurez 0-1; exposición relevante para el negocio.
Alto	Control con madurez 2 o no implementado con impacto acotado.
Medio	Control con madurez 3; implementado pero con oportunidades de mejora.
Bajo	Control con madurez 4-5; operando de forma consistente y supervisada.
N/A	Control fuera del alcance actual de la evaluación.

3. Resumen ejecutivo

La siguiente vista consolidada resume el estado general de los 93 controles evaluados.

93 Controles evaluados	41% Implementados	30% Parcialmente impl.
16% No implementados	31 Riesgo alto / crítico	2.8/5 Madurez promedio

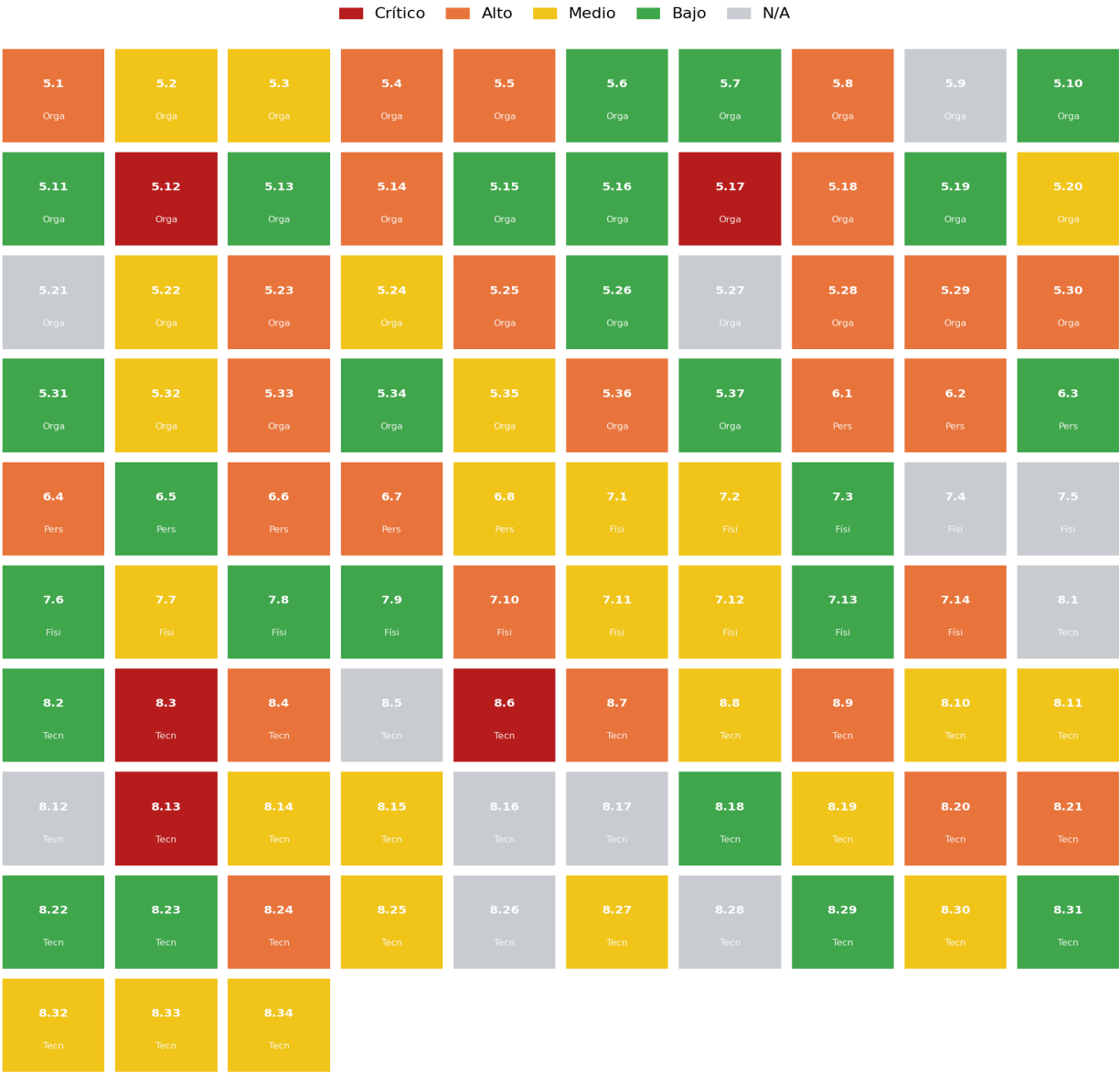
3.1 Resumen por dominio

Dominio	Controles	Implem.	Parcial	No impl.	Madurez prom.	Riesgo alto/crít.
Organizacional (A.5)	37	16	13	5	2.9	15
Personas (A.6)	8	2	3	3	2.0	5
Físico (A.7)	14	9	3	0	3.6	2
Tecnológico (A.8)	34	11	9	7	2.5	9

4. Mapa de calor general de riesgo

El siguiente mapa de calor muestra el nivel de riesgo residual asignado a cada uno de los 93 controles del Anexo A, identificados por su código y ordenados por dominio.

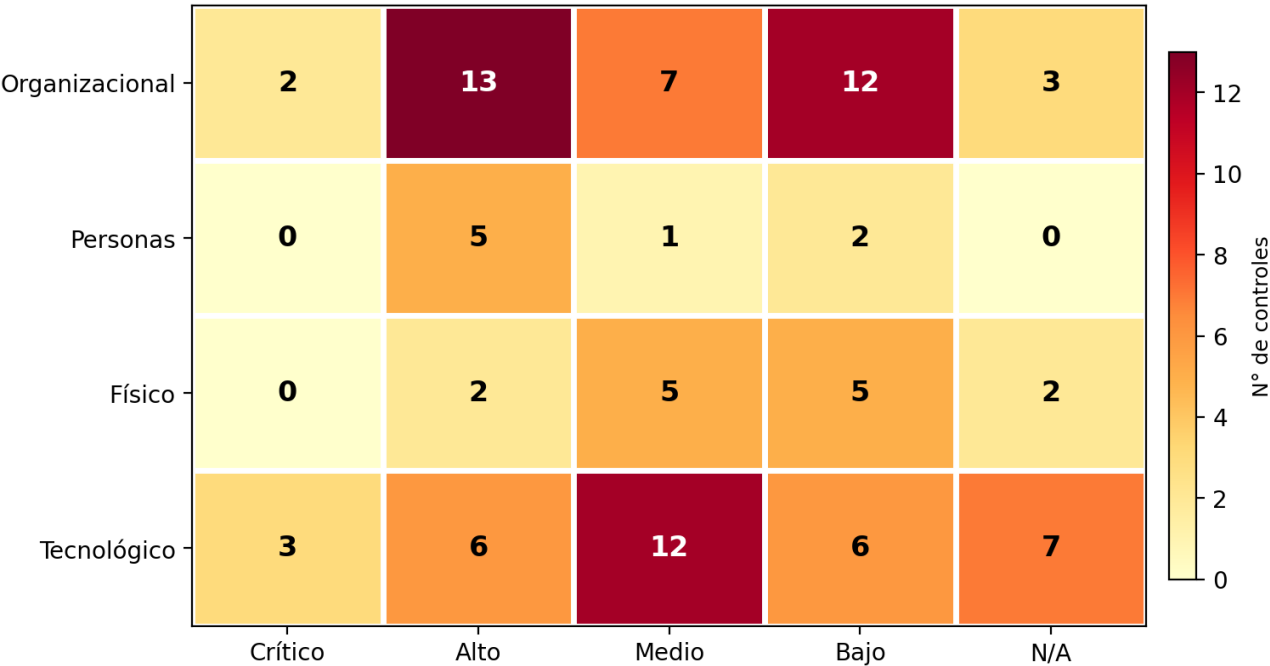
Mapa de calor general — Nivel de riesgo de los 93 controles (Anexo A, ISO/IEC 27001:2022)



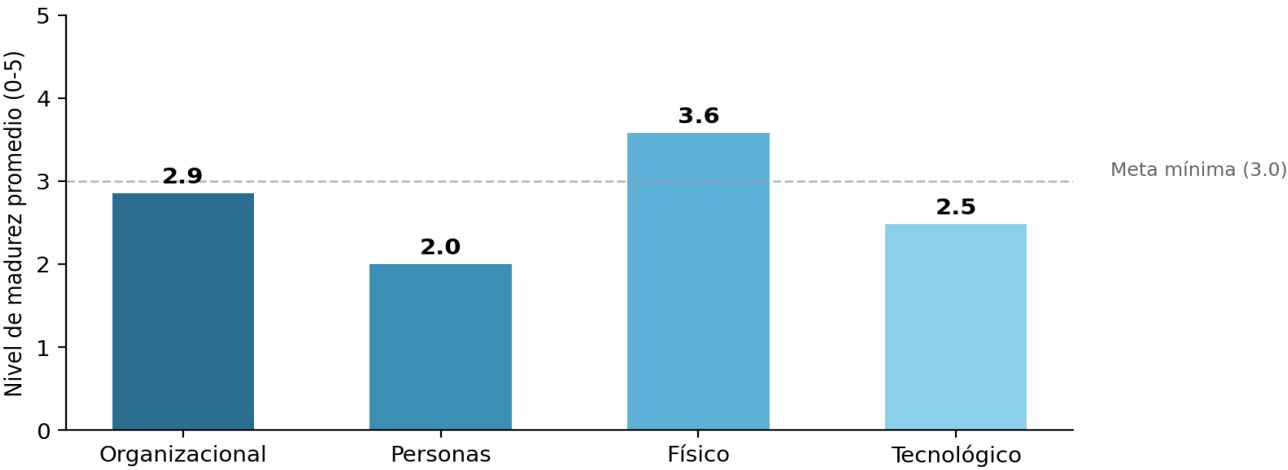
5. Mapa de calor y madurez por dominio

Esta vista agrupa los controles por dominio para identificar concentraciones de riesgo y comparar el nivel de madurez promedio alcanzado en cada uno.

Mapa de calor por dominio — Cantidad de controles según nivel de riesgo



Nivel de madurez promedio por dominio de control



6. Detalle de los 93 controles del Anexo A

A continuación se presenta el catálogo completo de controles evaluados, agrupado por dominio. La columna “Riesgo” está coloreada según el nivel asignado (ver leyenda en la sección 2.2).

6.1 Controles organizacionales (A.5 — 37 controles)

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.5.1	Políticas de seguridad de la información Define el marco general de directrices que guía la gestión de la seguridad en la organización.	Parcialmente implementado	2	Alto	Operaciones
A.5.2	Roles y responsabilidades de seguridad Asigna y comunica responsabilidades específicas de seguridad de la información.	Implementado	3	Medio	TI / Infraestructura
A.5.3	Segregación de funciones Evita que una sola persona controle de extremo a extremo procesos críticos o sensibles.	Implementado	3	Medio	Legal y Cumplimiento
A.5.4	Responsabilidades de la dirección Establece el compromiso y supervisión de la alta dirección con la seguridad.	Parcialmente implementado	2	Alto	Gestión de Riesgos
A.5.5	Contacto con autoridades Mantiene canales de comunicación con entidades regulatorias y de control.	Parcialmente implementado	2	Alto	Recursos Humanos
A.5.6	Contacto con grupos de interés especial Favorece el intercambio de información con foros y comunidades de seguridad.	Implementado	4	Bajo	Legal y Cumplimiento
A.5.7	Inteligencia de amenazas Recopila y analiza información sobre amenazas emergentes relevantes.	Implementado	5	Bajo	TI / Infraestructura
A.5.8	Seguridad en la gestión de proyectos Incorpora criterios de seguridad desde la planificación de proyectos.	Parcialmente implementado	2	Alto	Continuidad de Negocio
A.5.9	Inventario de activos de información Mantiene un registro actualizado de los activos y su responsable.	No aplica	—	N/A	Gestión de Riesgos
A.5.10	Uso aceptable de los activos Define reglas de uso adecuado de la información y los recursos asociados.	Implementado	4	Bajo	Legal y Cumplimiento
A.5.11	Devolución de activos Asegura la restitución de activos al finalizar una relación laboral o contractual.	Implementado	4	Bajo	Operaciones
A.5.12	Clasificación de la información Categoriza la información según su nivel de sensibilidad o criticidad.	No implementado	1	Crítico	Continuidad de Negocio
A.5.13	Etiquetado de la información Identifica visualmente el nivel de clasificación de la información.	Implementado	4	Bajo	Legal y Cumplimiento
A.5.14	Transferencia de información Protege la información durante su intercambio interno y externo.	Parcialmente implementado	2	Alto	Recursos Humanos
A.5.15	Control de acceso Restringe el acceso a la información según reglas de negocio definidas.	Implementado	5	Bajo	Operaciones

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.5.16	Gestión de identidades Administra el ciclo de vida de las identidades digitales.	Implementado	4	Bajo	Seguridad de la Información
A.5.17	Información de autenticación Protege credenciales y secretos de autenticación.	No implementado	1	Crítico	TI / Infraestructura
A.5.18	Derechos de acceso Otorga, revisa y revoca privilegios de acceso conforme a necesidad de uso.	No implementado	1	Alto	Continuidad de Negocio
A.5.19	Seguridad en relaciones con proveedores Gestiona los riesgos de seguridad derivados de terceros.	Implementado	4	Bajo	Legal y Cumplimiento
A.5.20	Seguridad en acuerdos con proveedores Incorpora cláusulas de seguridad en contratos con proveedores.	Parcialmente implementado	3	Medio	Gestión de Riesgos
A.5.21	Seguridad en la cadena de suministro TIC Gestiona riesgos asociados a la cadena de suministro tecnológico.	No aplica	—	N/A	Recursos Humanos
A.5.22	Supervisión de servicios de proveedores Monitorea y revisa el desempeño de seguridad de los proveedores.	Implementado	3	Medio	TI / Infraestructura
A.5.23	Seguridad en servicios en la nube Gestiona riesgos específicos del uso de servicios cloud.	No implementado	1	Alto	TI / Infraestructura
A.5.24	Planificación de gestión de incidentes Prepara a la organización para responder ante incidentes.	Parcialmente implementado	3	Medio	Operaciones
A.5.25	Evaluación de eventos de seguridad Determina si un evento debe clasificarse como incidente.	Parcialmente implementado	2	Alto	Operaciones
A.5.26	Respuesta a incidentes Ejecuta acciones de contención, erradicación y recuperación.	Implementado	5	Bajo	Recursos Humanos
A.5.27	Aprendizaje de incidentes Extrae lecciones aprendidas para reducir incidentes futuros.	No aplica	—	N/A	Operaciones
A.5.28	Recolección de evidencia Preserva evidencia digital de forma íntegra y trazable.	Parcialmente implementado	2	Alto	Operaciones
A.5.29	Seguridad durante la disrupción Mantiene controles mínimos de seguridad ante interrupciones.	Parcialmente implementado	2	Alto	Desarrollo de Software
A.5.30	Preparación TIC para continuidad Asegura la disponibilidad de infraestructura ante contingencias.	Parcialmente implementado	2	Alto	Desarrollo de Software
A.5.31	Requisitos legales y contractuales Identifica y cumple obligaciones legales y normativas aplicables.	Implementado	4	Bajo	Operaciones
A.5.32	Propiedad intelectual Protege los derechos de propiedad intelectual de la organización.	Implementado	3	Medio	TI / Infraestructura
A.5.33	Protección de registros Evita pérdida, alteración o acceso no autorizado a los registros.	No implementado	0	Alto	Continuidad de Negocio
A.5.34	Privacidad y protección de datos personales Resguarda la información personal conforme a normativa de privacidad.	Implementado	5	Bajo	Legal y Cumplimiento
A.5.35	Revisión independiente de seguridad Evalúa de forma objetiva el desempeño del sistema de gestión.	Parcialmente implementado	3	Medio	Desarrollo de Software
A.5.36	Cumplimiento de políticas y normas Verifica la adherencia a políticas y estándares internos.	Parcialmente implementado	2	Alto	Legal y Cumplimiento

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.5.37	Procedimientos operativos documentados Documenta procesos operativos para asegurar consistencia.	Implementado	4	Bajo	Legal y Cumplimiento

6.2 Controles de personas (A.6 — 8 controles)

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.6.1	Verificación de antecedentes Valida la idoneidad de candidatos antes de su contratación.	Parcialmente implementado	2	Alto	Legal y Cumplimiento
A.6.2	Términos y condiciones de empleo Establece responsabilidades de seguridad en el contrato laboral.	No implementado	0	Alto	Legal y Cumplimiento
A.6.3	Concienciación, educación y capacitación Forma al personal en buenas prácticas de seguridad.	Implementado	4	Bajo	Continuidad de Negocio
A.6.4	Proceso disciplinario Define consecuencias ante incumplimientos de seguridad.	No implementado	0	Alto	TI / Infraestructura
A.6.5	Responsabilidades tras la finalización Gestiona obligaciones de seguridad al término de la relación laboral.	Implementado	5	Bajo	Continuidad de Negocio
A.6.6	Acuerdos de confidencialidad Formaliza compromisos de no divulgación de información.	Parcialmente implementado	2	Alto	Seguridad de la Información
A.6.7	Trabajo remoto Protege la información cuando se trabaja fuera de las instalaciones.	No implementado	0	Alto	Legal y Cumplimiento
A.6.8	Reporte de eventos de seguridad Facilita que el personal informe eventos o debilidades observadas.	Parcialmente implementado	3	Medio	Recursos Humanos

6.3 Controles físicos (A.7 — 14 controles)

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.7.1	Perímetros de seguridad física Define barreras físicas para proteger áreas sensibles.	Implementado	3	Medio	Continuidad de Negocio
A.7.2	Control de entrada física Restringe el ingreso a instalaciones a personal autorizado.	Implementado	3	Medio	TI / Infraestructura
A.7.3	Seguridad de oficinas y recintos Protege espacios de trabajo frente a accesos no autorizados.	Implementado	5	Bajo	Continuidad de Negocio
A.7.4	Monitoreo de seguridad física Vigila instalaciones mediante sistemas de detección o videovigilancia.	No aplica	—	N/A	Recursos Humanos
A.7.5	Protección contra amenazas ambientales Mitiga riesgos de incendio, inundación u otros eventos físicos.	No aplica	—	N/A	Operaciones
A.7.6	Trabajo en áreas seguras Establece reglas adicionales para zonas de alta sensibilidad.	Implementado	5	Bajo	Recursos Humanos
A.7.7	Escritorio y pantalla limpios Reduce la exposición de información en puestos de trabajo.	Implementado	3	Medio	Seguridad de la Información
A.7.8	Emplazamiento y protección de equipos Ubica los equipos minimizando riesgos físicos y ambientales.	Implementado	5	Bajo	Recursos Humanos
A.7.9	Seguridad de activos fuera de instalaciones Protege equipos y dispositivos usados fuera de la organización.	Implementado	4	Bajo	TI / Infraestructura

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.7.10	Medios de almacenamiento Gestiona de forma segura el ciclo de vida de medios físicos.	Parcialmente implementado	2	Alto	Gestión de Riesgos
A.7.11	Servicios de soporte Asegura el suministro continuo de energía, agua y otros servicios.	Implementado	3	Medio	TI / Infraestructura
A.7.12	Seguridad del cableado Protege el cableado eléctrico y de datos de daños o interceptación.	Parcialmente implementado	3	Medio	Operaciones
A.7.13	Mantenimiento de equipos Garantiza el mantenimiento adecuado para su disponibilidad e integridad.	Implementado	5	Bajo	Recursos Humanos
A.7.14	Disposición segura o reutilización de equipos Elimina información de forma segura antes de desechar equipos.	Parcialmente implementado	2	Alto	Seguridad de la Información

6.4 Controles tecnológicos (A.8 — 34 controles)

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.8.1	Dispositivos de usuario final Protege equipos como laptops, móviles y estaciones de trabajo.	No aplica	—	N/A	TI / Infraestructura
A.8.2	Derechos de acceso privilegiado Restringe y supervisa cuentas con privilegios elevados.	Implementado	4	Bajo	Recursos Humanos
A.8.3	Restricción de acceso a la información Limita el acceso según el principio de mínimo privilegio.	No implementado	1	Crítico	Recursos Humanos
A.8.4	Acceso al código fuente Controla quién puede leer o modificar el código fuente.	Parcialmente implementado	2	Alto	Operaciones
A.8.5	Autenticación segura Implementa mecanismos robustos de verificación de identidad.	No aplica	—	N/A	Recursos Humanos
A.8.6	Gestión de capacidad Monitorea y planifica recursos para evitar degradación del servicio.	No implementado	0	Crítico	Operaciones
A.8.7	Protección contra malware Previene, detecta y responde ante software malicioso.	Parcialmente implementado	2	Alto	Operaciones
A.8.8	Gestión de vulnerabilidades técnicas Identifica y remedia vulnerabilidades de forma oportuna.	Implementado	3	Medio	TI / Infraestructura
A.8.9	Gestión de configuración Mantiene configuraciones seguras y documentadas de los sistemas.	No implementado	0	Alto	Desarrollo de Software
A.8.10	Eliminación de información Elimina datos de forma segura cuando ya no son necesarios.	Parcialmente implementado	3	Medio	Recursos Humanos
A.8.11	Enmascaramiento de datos Oculta información sensible en entornos no productivos.	Parcialmente implementado	3	Medio	Seguridad de la Información
A.8.12	Prevención de fuga de datos Detecta y previene la exfiltración no autorizada de información.	No aplica	—	N/A	Recursos Humanos
A.8.13	Copias de respaldo de información Asegura la disponibilidad de copias de respaldo confiables.	No implementado	0	Crítico	Recursos Humanos
A.8.14	Redundancia de instalaciones de procesamiento Garantiza continuidad mediante componentes redundantes.	Implementado	3	Medio	Desarrollo de Software

Código	Control / objetivo	Estado	Madurez	Riesgo	Responsable
A.8.15	Registro de eventos (logging) Genera registros que permiten trazabilidad y auditoría.	Parcialmente implementado	3	Medio	Gestión de Riesgos
A.8.16	Actividades de monitoreo Supervisa sistemas para detectar comportamientos anómalos.	No aplica	—	N/A	Legal y Cumplimiento
A.8.17	Sincronización de relojes Asegura coherencia temporal entre sistemas para la trazabilidad.	No aplica	—	N/A	Recursos Humanos
A.8.18	Uso de programas utilitarios privilegiados Restringe el uso de herramientas que pueden sortear controles.	Implementado	4	Bajo	Gestión de Riesgos
A.8.19	Instalación de software en sistemas operativos Controla qué software puede instalarse en producción.	Implementado	3	Medio	Gestión de Riesgos
A.8.20	Seguridad de redes Protege la infraestructura de red frente a accesos indebidos.	No implementado	0	Alto	Continuidad de Negocio
A.8.21	Seguridad de los servicios de red Define requisitos de seguridad para servicios de red.	No implementado	0	Alto	Seguridad de la Información
A.8.22	Segregación de redes Separa segmentos de red según criticidad o función.	Implementado	4	Bajo	TI / Infraestructura
A.8.23	Filtrado web Restringe el acceso a sitios web potencialmente riesgosos.	Implementado	5	Bajo	Desarrollo de Software
A.8.24	Uso de criptografía Define el uso adecuado de cifrado para proteger la información.	No implementado	1	Alto	Operaciones
A.8.25	Ciclo de vida de desarrollo seguro Integra la seguridad en todas las fases del desarrollo de software.	Parcialmente implementado	3	Medio	Desarrollo de Software
A.8.26	Requisitos de seguridad de aplicaciones Define requisitos de seguridad antes de construir aplicaciones.	No aplica	—	N/A	TI / Infraestructura
A.8.27	Principios de arquitectura segura Aplica principios de diseño seguro en la arquitectura de sistemas.	Implementado	3	Medio	Gestión de Riesgos
A.8.28	Codificación segura Aplica prácticas de programación que reducen vulnerabilidades.	No aplica	—	N/A	Legal y Cumplimiento
A.8.29	Pruebas de seguridad en desarrollo Verifica la seguridad del software antes de su puesta en producción.	Implementado	4	Bajo	Desarrollo de Software
A.8.30	Desarrollo externalizado Gestiona riesgos de seguridad en desarrollos realizados por terceros.	Parcialmente implementado	3	Medio	Operaciones
A.8.31	Separación de entornos Aísla los entornos de desarrollo, prueba y producción.	Implementado	4	Bajo	Recursos Humanos
A.8.32	Gestión de cambios Controla los cambios en sistemas para evitar impactos no deseados.	Parcialmente implementado	3	Medio	Recursos Humanos
A.8.33	Información de prueba Protege los datos utilizados en entornos de prueba.	Implementado	3	Medio	Operaciones
A.8.34	Protección de sistemas durante auditorías Minimiza el impacto operativo de las actividades de auditoría técnica.	Parcialmente implementado	3	Medio	Continuidad de Negocio

7. Conclusiones y recomendaciones generales

Con base en los datos de prueba generados para este ejercicio, se observan concentraciones de riesgo alto y crítico principalmente en controles organizacionales vinculados a gestión de incidentes y relación con proveedores, así como en controles tecnológicos relacionados con gestión de vulnerabilidades, copias de respaldo y protección contra malware. El dominio de controles físicos presenta, en este conjunto de datos, el nivel de madurez promedio más alto.

Recomendaciones generales orientativas (a modo de ejemplo):

- Priorizar el cierre de brechas en los controles calificados con riesgo crítico antes de los de riesgo alto.
- Reforzar la asignación de responsables y fechas de seguimiento para los controles parcialmente implementados.
- Incorporar revisiones periódicas de madurez (al menos semestrales) para sostener la mejora continua.
- Validar que los controles marcados como “No aplica” cuenten con una justificación documentada.

Nota: este documento fue generado íntegramente con datos sintéticos como material de prueba para un agente de análisis de inteligencia artificial. No debe utilizarse como evidencia de cumplimiento real ni como sustituto del texto oficial de la norma ISO/IEC 27001.